

STIX 2.1 — Cheat Sheet

Model intelligence as a shareable, machine-readable graph. For CTI / structured OSINT.

What & why

STIX (Structured Threat Information eXpression) is an OASIS open standard (v2.1) that describes intelligence as a **graph** of typed JSON objects. **TAXII** is the protocol that moves STIX between tools. Your investigation stops being loose notes and becomes queryable, auditable and interoperable.

The three families

Family	Role	Examples
SDO — Domain Objects	the entities	<code>identity</code> , <code>threat-actor</code> , <code>intrusion-set</code> , <code>campaign</code> , <code>malware</code> , <code>tool</code> , <code>attack-pattern</code> , <code>indicator</code> , <code>vulnerability</code> , <code>infrastructure</code> , <code>report</code> , <code>note</code> , <code>opinion</code> , <code>location</code> , <code>course-of-action</code>
SCO — Cyber-observables	the technical facts	<code>domain-name</code> , <code>ipv4-addr</code> , <code>url</code> , <code>file</code> , <code>email-addr</code> , <code>email-message</code> , <code>user-account</code> , <code>x509-certificate</code> , <code>autonomous-system</code>
SRO — Relationship Objects	the links	<code>relationship</code> (source_ref → target_ref), <code>sighting</code>

Common relationship types: `uses`, `targets`, `indicates`, `attributed-to`, `communicates-with`, `located-at`, `mitigates`.

Every object carries

<code>id</code>	<code>type--UUID</code>	(e.g. <code>indicator--<uuid></code>)
<code>spec_version</code>	<code>"2.1"</code>	
<code>created / modified</code>	<code>UTC timestamps</code>	
<code>created_by_ref</code>	<code>identity--...</code>	(provenance)
<code>confidence</code>	<code>0-100</code>	
<code>object_marking_refs</code>	<code>[TLP marking]</code>	
<code>external_references</code>	<code>[links to CVE, MITRE ATT&CK, reports]</code>	

TLP (Traffic Light Protocol) — how far it travels

Marking	Share with
<code>TLP:CLEAR</code>	anyone
<code>TLP:GREEN</code>	the community
<code>TLP:AMBER</code>	your organisation (+ clients, need-to-know)
<code>TLP:RED</code>	named recipients only

Never share above the TLP. Never state a fact above its confidence.

Confidence ↔ Admiralty (Day 2)

Map source reliability (A–F) × info credibility (1–6) onto `confidence` + an `Opinion`:

Admiralty	confidence	Opinion
A1 / A2	95 / 80	strongly-agree / agree
B2 / C3	80 / 60	agree / neutral
D4 / E5	40 / 20	disagree / strongly-disagree

Take the cautious value: `confidence = min(source, info)`.

Indicator patterning

```
[domain-name:value = 'evil.example.com']  
[ipv4-addr:value = '185.199.51.23']  
[file:hashes.'SHA-256' = 'ab12...']  
[email-addr:value = 'phish@evil.tld'] AND [domain-name:value = 'evil.tld']
```

Build it in Python (stix2)

```
from stix2 import Indicator, ThreatActor, Relationship, Bundle, TLP_AMBER  
ind = Indicator(name="phish domain", pattern_type="stix",  
               pattern="[domain-name:value = 'evil.tld']",  
               valid_from="2026-01-01T00:00:00Z", confidence=80,  
               object_marking_refs=[TLP_AMBER])  
ta = ThreatActor(name="UNC-Falcon", object_marking_refs=[TLP_AMBER])  
rel = Relationship(ind, "indicates", ta)  
bundle = Bundle(ind, ta, rel, TLP_AMBER)  
open("bundle.json", "w").write(bundle.serialize(indent=2))
```

```
import stix2, pathlib  
b = stix2.parse(pathlib.Path("bundle.json").read_text()) # strict parse = validation
```

```
pip install stix2 stix2-validator  
stix2_validator bundle.json # schema + best-practice checks
```

MITRE ATT&CK

ATT&CK is published **as STIX**. Reference a technique by id (not by copying text):

```
"external_references": [  
  { "source_name": "mitre-attack", "external_id": "T1566.002",  
    "url": "https://attack.mitre.org/techniques/T1566/002/" } ]
```

Ecosystem

Tool	Role
OpenCTI	team knowledge-graph platform (STIX-native); pycti to push
MISP	sharing platform; imports/exports STIX
TAXII 2.1	transport: collections you POST bundles to / poll
MITRE ATT&CK	technique catalogue, distributed as STIX
n8n	orchestrate collectors → STIX writer → OpenCTI (see Docker & n8n Lab)

Minimal report object (group an investigation)

```
{ "type": "report", "spec_version": "2.1", "id": "report--...",  
  "name": "UNC-Falcon phishing", "published": "2026-01-01T09:00:00Z",  
  "confidence": 75, "object_refs": ["threat-actor--...", "indicator--..."],  
  "object_marking_refs": ["marking-definition--tlp-amber"] }
```

Golden rule: nodes (SDO/SCO) + typed edges (SRO), each with provenance, TLP and confidence. Build, validate, share — the same finding, understood everywhere.